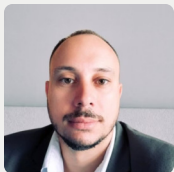


Portfólio Profissional – Mauro Costa

**Segurança da Informação com visão de negócio,
governança e entrega de projetos.**



Sou Mauro Costa, profissional de Segurança da Informação, GRC e Gestão de Projetos em Cybersecurity.

Atuo na estruturação de processos, avaliação de riscos, segurança em desenvolvimento, gestão de vulnerabilidades, proteção de dados e governança de segurança aplicada ao negócio.

Meu objetivo é apoiar empresas na redução de riscos cibernéticos, aumento da maturidade em segurança e organização de controles, indicadores e processos de proteção digital.

**Segurança da
Informação**

GRC

Gestão de Riscos

TPRM

ISO 27001

NIST CSF

DevSecOps

Cloud Security

Sobre Mim

Sou profissional de Segurança da Informação com experiência em ambientes corporativos complexos, projetos de Cybersecurity, Governança, Riscos, Compliance, Segurança em Desenvolvimento e Gestão de Projetos de TI/Telecom.

Minha trajetória une conhecimento técnico e visão estratégica. Atuo conectando riscos cibernéticos, controles de segurança, fornecedores, squads de desenvolvimento, indicadores executivos e necessidades do negócio.

Tenho experiência em:

Segurança da Informação e GRC

Gestão de Riscos Cibernéticos

Third-Party Risk Management

Avaliação de fornecedores e parceiros

ISO 27001, ISO 27005, NIST CSF e CIS Controls

S-SDLC, SDLC, AppSec e DevSecOps

Gestão de vulnerabilidades

Segurança em ambientes AWS e Azure

Indicadores KRIs/KPIs

Gestão de projetos e stakeholders

Minha atuação é orientada por governança, ética, melhoria contínua, visão de risco e comunicação clara entre áreas técnicas e executivas.

Ferramentas e frameworks

NIST CSF, ISO 27001, ISO 27005, CIS Controls, LGPD, AWS, Azure, OneTrust, SecurityScorecard, Qualys, Guardicore, Cisco FMC, Netskope, Trend Micro Deep Security, Microsoft Intune, Checkpoint Harmony, SAST, DAST, SCA e STRIDE.

Case 1 – Estruturação de S-SDLC em Squads Ágeis

Contexto

Em um ambiente corporativo com produtos digitais e squads de desenvolvimento, havia a necessidade de inserir segurança no ciclo de vida do software sem tornar o processo lento ou burocrático.

Meu papel foi apoiar a estruturação de práticas de S-SDLC, levando segurança para as etapas de desenvolvimento, análise de risco, testes e validação dos produtos.

Processo

O trabalho começou com a análise do fluxo existente de desenvolvimento e dos principais pontos de risco.

A partir disso, foram estruturadas práticas de segurança aplicadas ao modelo ágil, com apoio às squads, revisão de riscos, modelagem de ameaças e integração de controles ao processo.

Foram utilizadas práticas como:

Risk Assessment	STRIDE
SAST	DAST
SCA	DevSecOps
análise de testes de intrusão	acompanhamento de vulnerabilidades

Resultado

O projeto contribuiu para elevar a maturidade de segurança dos produtos digitais, aproximar Segurança da Informação dos times de desenvolvimento e transformar segurança em parte do processo, e não apenas em uma etapa final de validação.

Entregáveis principais:

- Processo de S-SDLC estruturado
- apoio técnico às squads
- relatórios de risco cibernético
- recomendações de mitigação
- indicadores de maturidade e risco

Case 2 – Gestão de Riscos de Terceiros e Fornecedores

Contexto

Empresas que dependem de fornecedores, parceiros e soluções externas precisam avaliar a postura de segurança desses terceiros para reduzir riscos na cadeia de suprimentos digital.

Nesse cenário, atuei na estruturação e execução de processos de Third-Party Risk Management, com foco em avaliação de fornecedores, riscos cibernéticos, proteção de dados e controles de segurança.

Processo

A atuação envolveu avaliação da postura de segurança dos fornecedores, classificação dos riscos, análise de evidências, identificação de gaps e recomendação de planos de tratamento.

O trabalho considerou boas práticas e frameworks como:

ISO 27005

NIST C-SCRM

NIST CSF

LGPD

SecurityScorecard

OneTrust

avaliação de controles

auditoria de fornecedores

Resultado

O projeto apoiou a organização na redução de riscos relacionados a terceiros, aumentando a visibilidade sobre fornecedores críticos e fortalecendo a governança de segurança na cadeia de suprimentos.

Entregáveis principais:

- fluxo de TPRM
- avaliação de fornecedores
- classificação de riscos
- recomendações de tratamento
- documentação de evidências
- apoio à governança de terceiros

Case 3 – Gestão de Vulnerabilidades em Ambientes Cloud

Contexto

Ambientes em nuvem exigem monitoramento contínuo de postura de segurança, identificação de vulnerabilidades e priorização de correções com base em risco.

Atuei na gestão de vulnerabilidades em produtos digitais hospedados em ambientes AWS e Azure, com foco em maturidade, acompanhamento técnico e redução de exposição.

Processo

O trabalho envolveu identificação de vulnerabilidades, análise de criticidade, abertura e acompanhamento de chamados junto às equipes técnicas, validação de correções e monitoramento da maturidade de segurança.

Foram considerados aspectos como:



Resultado

A atuação contribuiu para melhorar a visibilidade dos riscos em cloud, organizar o acompanhamento de correções e apoiar a evolução da maturidade de segurança dos produtos digitais.

Entregáveis principais:

- acompanhamento de vulnerabilidades
- priorização de correções
- interação com times técnicos
- relatórios de risco
- indicadores de maturidade

Case 4 – Indicadores Executivos de Segurança

Contexto

A liderança precisa de informações claras para tomar decisões sobre riscos, vulnerabilidades, fornecedores e maturidade de segurança.

Nesse contexto, atuei na elaboração e apresentação de KRIs e KPIs de risco e segurança, traduzindo temas técnicos em linguagem executiva.

Processo

O trabalho envolveu coleta de informações técnicas, consolidação dos dados, análise dos principais riscos, organização dos indicadores e preparação de apresentações para gestão.

Os indicadores apoiaram temas como:

maturidade de segurança

riscos dos produtos digitais

vulnerabilidades

evolução dos planos de ação

postura de fornecedores

priorização de riscos

Resultado

A iniciativa contribuiu para dar mais visibilidade aos riscos de segurança, apoiar decisões gerenciais e melhorar a comunicação entre Segurança da Informação, tecnologia e negócio.

Entregáveis principais:

- KRIs
- KPIs
- apresentações executivas
- relatórios de maturidade
- visão consolidada de riscos
- recomendações de priorização

Case 5 – Microsegmentação e Segurança de Rede

Contexto

Ambientes corporativos com alta complexidade precisam reduzir exposição, limitar movimentações indevidas e fortalecer controles de rede.

Atuei em projetos de microsegmentação e segurança perimetral, apoiando arquitetura, sustentação de ferramentas e acompanhamento técnico das entregas.

Processo

A atuação envolveu suporte especializado, reuniões de status, alinhamento com stakeholders, documentação técnica e apoio à sustentação de soluções de segurança.

Foram utilizadas tecnologias e temas como:

Guardicore

Cisco Firepower Management Center

microsegmentação

segurança perimetral

arquitetura de segurança

status report

sustentação de ferramentas

Resultado

O projeto apoiou a evolução dos controles de segurança de rede, melhorando a organização técnica, a visibilidade das entregas e o alinhamento entre áreas envolvidas.

Entregáveis principais:

- acompanhamento de projeto
- suporte técnico especializado
- documentação
- status reports
- apoio à arquitetura
- sustentação de ferramentas

Case 6 – Delivery de Projetos de Cybersecurity

Contexto

Projetos de Cybersecurity exigem coordenação entre áreas técnicas, fornecedores, documentação, testes, implantação e sustentação.

Com experiência prévia em Gestão de Projetos de TI/Telecom, atuei no delivery de projetos de segurança, conectando execução técnica, governança e controle de entregas.

Processo

A atuação incluiu gestão de fornecedores, acompanhamento de backlog, changes, sprints, caderno de testes, use cases, documentação, treinamentos e interação com times internos e externos.

Foram trabalhadas tecnologias como:

Netskope

Guardicore

Trend Micro Deep Security

Microsoft Intune

Checkpoint Harmony

ferramentas de segurança corporativa

Resultado

A atuação contribuiu para organizar entregas, acompanhar dependências, reduzir ruídos entre áreas técnicas e fortalecer a execução de projetos de segurança em ambientes corporativos.

Entregáveis principais:

- gestão de backlog
- acompanhamento de changes
- documentação técnica
- caderno de testes
- use cases
- treinamentos
- alinhamento com fornecedores
- sustentação de tecnologias

Depoimentos e Prova Social

Esta seção pode ser preenchida com recomendações de gestores, colegas, clientes internos, fornecedores ou conexões do LinkedIn.

Sugestões de depoimentos a solicitar

Gestor direto

"Mauro atuou com responsabilidade técnica, visão de risco e capacidade de traduzir temas complexos de Segurança da Informação para decisões práticas de negócio."

Colega de squad ou tecnologia

"Mauro contribuiu para aproximar Segurança da Informação dos times de desenvolvimento, apoiando a adoção de práticas de S-SDLC, DevSecOps e gestão de vulnerabilidades."

Fornecedor ou parceiro

"Mauro conduziu as interações técnicas com clareza, organização e foco em solução, mantendo boa comunicação entre áreas envolvidas no projeto."

Liderança ou stakeholder

"Mauro apresentou indicadores e riscos de forma objetiva, apoiando a priorização de ações e a evolução da maturidade de segurança."

Provas sociais recomendadas

- Recomendações no LinkedIn
- Certificações em NIST, ISO, CIS Controls e Guardicore
- Projetos de S-SDLC, TPRM, Cloud Security e Cybersecurity
- Experiência em ambientes corporativos regulados
- Atuação com áreas técnicas, fornecedores, squads e liderança

Contato

Vamos conversar sobre Segurança da Informação, GRC, Gestão de Riscos, TPRM ou projetos de Cybersecurity?

Mauro Costa Especialista em Segurança da Informação | GRC | Gestão de Riscos
| Projetos em Cybersecurity

LinkedIn: <http://www.linkedin.com/in/mauro-costa-928193230>

E-mail: mauroscosta2014@gmail.com

Celular: 11 94499-3326

Serviços que posso apoiar

- **Diagnóstico de maturidade em Segurança da Informação**
- **Assessment de riscos de terceiros e fornecedores**
- **Roadmap de GRC, ISO 27001, NIST CSF e CIS Controls**
- **Apoio em S-SDLC, AppSec e DevSecOps**
- **Gestão de vulnerabilidades e segurança em cloud**
- **Estruturação de indicadores KRIs/KPIs**
- **Gestão de projetos de Cybersecurity**